ProofPatch

Ship the fix.
Keep the proof.

Three agents. One reviewable security workflow.

> For small SaaS teams protecting customer data without a dedicated AppSec engineer.

The gap between finding and fixing matters.

31%

of breaches began with vulnerability exploitation

Verizon 2026 DBIR
Based on 2025 incident data

01	Find the relevant risk
02	Reproduce it in our app
03	Patch without breaking behavior
04	Give the reviewer usable evidence

Source: Verizon 2026 DBIR announcement. Industry context does not establish demand for ProofPatch.

Start with a specific developer workflow.

Initial customer hypothesis

5–30 developers
TypeScript / Node SaaS
Tenant-scoped customer data

CTO buys. Developer uses.
No dedicated AppSec engineer.

“Can I merge this fix without breaking a customer?”

Alert context is incomplete.
Reproduction needs real application setup.
Review evidence is scattered.

Validation needed: observe five real workflows and identify the largest source of active developer effort.

Three roles. A gate no agent can override.

01

Scout

Map dependencies and code signals. Prioritize with context.

02

Challenger

Reproduce the failure. Freeze the security test and benign controls.

03

Fixer

Propose a scoped patch. Explain compatibility and tradeoffs.

REPLAY + POLICY GATE

Baseline fails. Candidate passes. Normal behavior survives.

Matching test and commit identities. Human review owns the merge.

One failure a judge can understand.

Tenant B requests Tenant A’s invoice.

Before

200

Unauthorized data access

After proposed fix

404

Access denied; owner still gets 200

If legitimate access breaks, the patch is blocked. All outcomes here are simulated.

The competition already fixes and verifies.

Alternative	Documented capability
Dependabot	Dependency security-update pull requests
GitHub Agentic Autofix	Code fixes, CodeQL rerun, draft PR for review
Snyk Agent Fix	Agentic remediation for Snyk Code findings
Aikido Infinite	Continuous testing, AutoFix and retesting

Our proposed focus

Portable tenant-boundary regression packs, customer-owned execution, and bounded onboarding for small teams.

A pilot offer with measurable economics.

₹4,999

per workspace / month

3 repositories
30 bounded validation runs
CTO or engineering lead buys

Illustrative monthly cost

Model + compute	**₹750**
Infrastructure	**₹500**
Total variable cost	**₹1,250**
Contribution	**₹3,749 / 75%**

Hypotheses, not results. At ₹100/run, contribution falls to 30%. Excludes support, salaries, tax and sales.

Earn three pilots before building a platform.

10

interviews

Understand recent work

5

observations

Watch real alert resolution

3

scoped pilots

Use owned staging fixtures

2

paid commitments

Test willingness to pay

Distribution hypothesis: incubators, SaaS communities, then a reproducible GitHub demo.

Two-week validation targets. No interviews, pilots, paid commitments or partnerships are claimed today.

Measure value. Keep the business claims honest.

Outcome to test

30% less active remediation time on matched pilot tasks. A target, not an achieved result.

Trust to earn

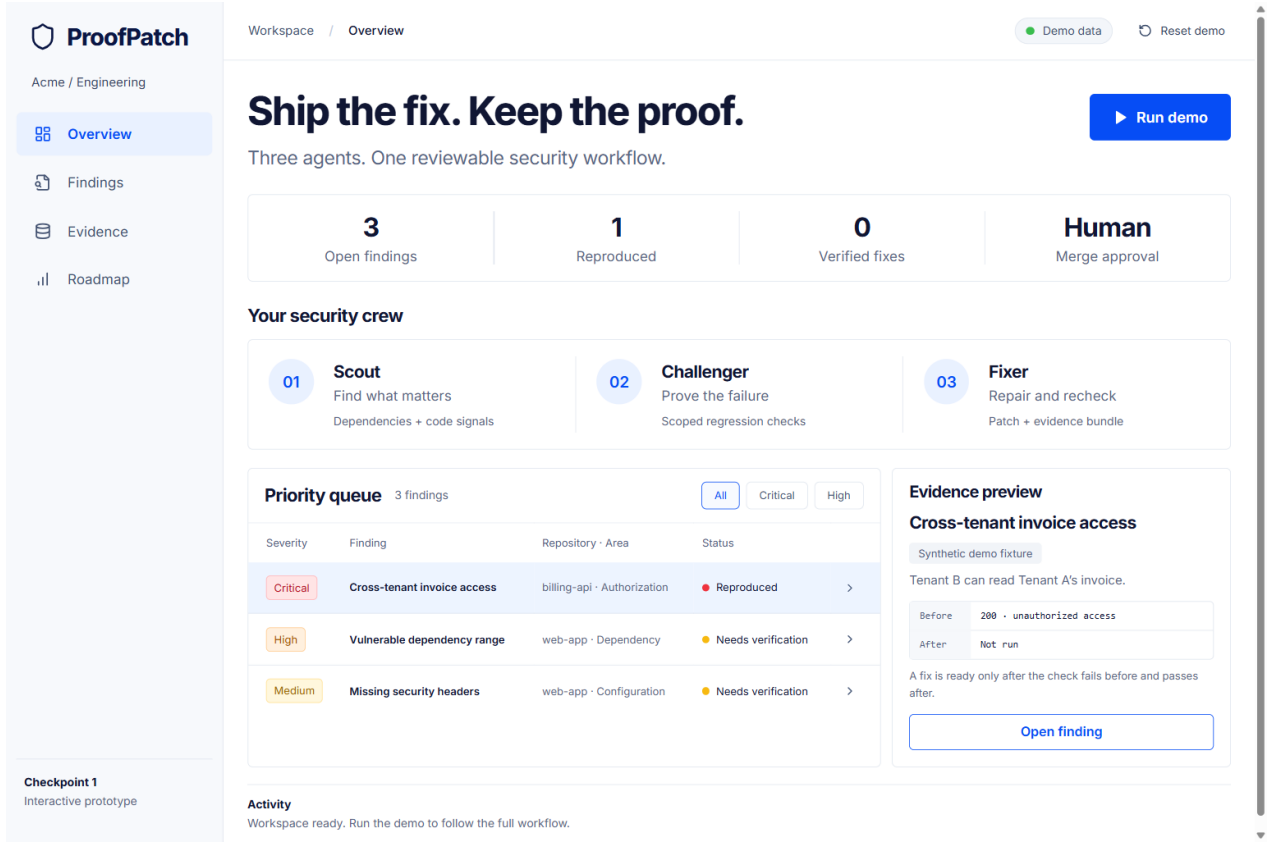
No bad-patch promotion on the controlled benchmark. Publish failures and coverage limits.

₹59.988 lakh

100 paying workspaces × ₹4,999 × 12

Illustrative annual revenue scenario.
Not market size, traction or a forecast.

Checkpoint 1: show the workflow, state the limits.



Built

Interactive prototype
Local workflow + failure gate
Synthetic evidence export

Next: working MVP

Real scanner + isolated fixture
Before/after test execution
Draft PR with evidence

Four-member team. Provisional 48-hour MVP plan. Ask: three design partners and feedback on trust and onboarding.

Architecture: evidence crosses every boundary.

Reviewer UI

Next.js

Orchestrator

Hono + bounded queue

Execution

Customer-owned runner

Scout

Advisory / code signals

Challenger + Fixer

Baseline / patch / replay

Evidence gate

Deterministic rules

Postgres records + scrubbed artifact store

Pinned commits and frozen tests. Scoped tokens. Allowlisted staging.
Run budgets. Human review. No autonomous production merge.

Sources and status

Verizon 2026 DBIR	Industry breach context
GitHub Dependabot + Agentic Autofix	Security-update PRs and code remediation
Snyk Agent Fix	Agentic remediation documentation
Aikido Infinite	Continuous testing, fixes and retesting
OSV-Scanner + ZAP baseline	Tool options and passive-scan limits

Checked 24 Oct 2026. Full URLs in speaker notes and PRD. Prototype results, pricing and pilot targets are not production evidence.